MAINFRAME SECURITY

POLICY NUMBER - WyIT - 3022

PURPOSE: This policy describes procedures and standards for personnel performing security duties on the Wyoming mainframe computer.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by WyIT - 3002 - Security Exception Request policy.

IV. ROLES

- Mainframe Users: any user or affiliate with a Mainframe account.
- ETS Security Liaison: control ETS access to mainframe and who has agency security liaison access.
- Agency Mainframe Security Liaisons: control who has access to the agency's mainframe environment.

V. APPOINTMENT OF MAINFRAME SECURITY LIAISONS

Upon receipt of a letter from an agency director appointing or changing their

appointed liaisons, the ETS mainframe liaison submits changes for the respective mainframe users to change their permissions in accordance with the director's letter. The agency director's letter is kept on file by the ETS security liaison for reference.

VI. MAINFRAME SECURITY LIAISON RESPONSIBILITIES

- Agency Mainframe Security Liaisons perform access control duties for their respective agency's personnel, authorizing user access to their respective agency's data. They submit F541 forms to add, change, or delete users on the mainframe.
- Agency Mainframe Security Liaisons are authorized to approve external data connections to their agency's data upon approval from the ETS Network Security team.
- The ETS Mainframe liaison, in addition to ETS mainframe security liaison duties, processes requests from agencies for changes to their respective security liaisons.

VII. ACCESS CONTROL

- For the purposes of this document, there are two mainframe account types: user and security liaison. A user is any person or affiliate with an assigned mainframe account. A Security Liaison is a user designated by an agency director's letter with authority and responsibility to manage mainframe permissions on behalf of that agency.
    - Mainframe security liaisons are specific people appointed by their respective agency directors via letter to act on behalf of their agency to grant access to the mainframe.
    - Agency Security liaisons approve permissions for those who have access permissions to the mainframe for their respective agency. Access permissions are granted only for their respective user role to perform their duties.
    - The ETS security liaison is appointed by letter from the ETS director and keeps letters received from other agency directors designating their respective agencies' mainframe security liaisons. The ETS security liaison grants mainframe permissions to other agencies' security liaisons and ETS users.
    - Remote Access Allowances.

i. Access to the mainframe is mediated through access to the WY State Network and accounts access granted by a security liaison.
ii. Remote access is allowed, and in many cases required, to perform needed duties by authorized personnel utilizing citrix, Bluezone client software, FTP, and web-based CICS access.
iii. IBM personnel operating at the Omaha site have authorized mainframe access without going through the WY State Network. Instead they use a jump-box local to the mainframe. These personnel still require account access granted by the ETS security liaison for access.

- Agency Security Liaisons are granted permission by the ETS Security Liaison to access and submit F541 form(s) in order to add, change or modify access to the mainframe. Mainframe batch jobs are run on business days to process these security liaison requests. These requests specify users' RACF security groups and billing information which designate these users' specific access and billing.
- New mainframe security liaisons are provided on-the-job-training either by their predecessor or by the ETS mainframe security liaison on how to submit F541s.
- In some instances, the agency liaison may need to coordinate with the ETS liaison to manually change permissions.
- ETS only changes permissions for mainframe access as directed by that agency's designated liaison, their agency's administrator, or as defined in this policy.
- When a F541 is submitted to delete a user, that user's access is revoked during the next processing run of forms. These processing runs are scheduled to run twice a day. When a Delete Request is processed, the user-ID is revoked and can no longer be used to access the mainframe. If a situation arises where immediate revocation of permissions are needed, contact the ETS liaison to request manual revocation.
- At the end of the month, accounts flagged for deletion are processed during RACF (Resource Access Control Facility) month-end activities. Files associated with the deleted user-ID are referred to the agency's liaison for disposition. The associated user ID remains on the mainframe with all login and access privileges removed in order to keep that user ID from being reassigned to another user.
- Security screenings.
  i. State employees go through security screenings as part of the hiring

process, per Wyoming statute 7-19-201, and this is considered sufficient for providing mainframe access insofar as it is necessary for them to do their duties.

ii. All contractors using the mainframe are also required to have a security screening as part of the hiring process. In addition, contractors are required to complete FTI training annually. See section Security Awareness and Training.

iii. Contractor access. Contractors' mainframe accounts are given a one-year termination from the account creation date. If the contractor is still working for the state this expiration date needs to be extended by the respective agency security liaison 30 days prior to expiration.

VIII. ACCESS REVOCATION

- Notification.
  - The HR department of the mainframe using agency will notify their respective agency security liaison of personnel leaving the agency so the appropriate account cancellation forms can be submitted and the user accounts access revoked.
  - The contracting agency will notify the mainframe security liaison of mainframe using personnel who have been removed from mainframe-using duties so that the appropriate account cancellation forms can be submitted and the user accounts access revoked.
  - Accounts that may be missed will be identified through RACF automated reports that the respective accounts have been inactive over 30 days.
- The following cases will result in a user's access being revoked.
  - The user does not complete their F541 acknowledgement form within the ten-day window provided. This results in an automatic revocation. A manual extension is needed to extend the revoke date.
  - If 60 days have elapsed since the user's last login. The system automatically revokes unused accounts.
  - Accounts with more than 30 days of inactivity will be marked for deletion at the 60 day mark.
  - The mainframe security liaison submits a F541 to delete that user's account. Revocation is processed during the next F541 daily batch processing.
  - Contractor accounts have a revoke date up to one year from their creation or last extension. Contractors working on the mainframe beyond that date need to have their account revoke date extended by their respective liaison.

Failure to do so results in automatic revocation of access privileges until the account is extended.

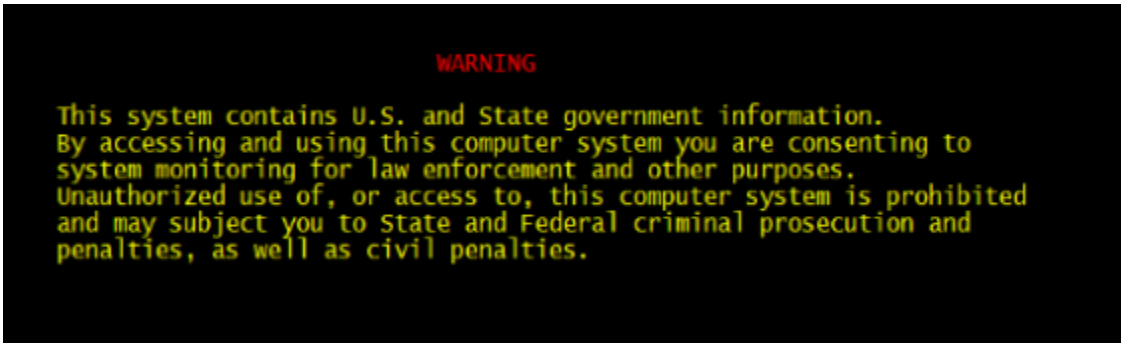
- Three consecutive unsuccessful attempts over any time period to log in will result in the account being locked. The account will remain locked until it is manually unlocked by a security liaison.
- A user's session will be locked after 15 minutes of inactivity, requiring the user to enter their password again. Exceptions may be made for WYDOT employees with specific job requirements, i.e. Highway Patrol.

IX. COORDINATION BETWEEN ETS MAINFRAME LIAISON AND AGENCY MAINFRAME LIAISONS

- Agency liaisons manage access to their respective agencies' data. The ETS liaison provides monthly automated reports to agency liaisons to empower them to manage their respective accounts.
- Changes to data access between the mainframe systems other than users, i.e. access requiring firewall changes, FTP accounts, etc. are coordinated through the agency liaison and ETS liaison as needed.
- The ETS liaison will also coordinate with agency liaisons regarding potential security violations.

X. LOGIN BANNER

A government system banner will be displayed to all users when logging in announcing that this is a government system and unauthorized access is prohibited. Below is an example of the banner.



XI. PASSWORD REQUIREMENTS

- The RACF (Resource Access Control Facility) system enforces password standards. Mainframe passwords must:
  - Be 14 characters in length
  - Begin and end with an alphabetic character
  - Contain at least 1 numeric digit in positions 2-7
  - Not contain special characters
  - Not be repeated within 24 historic generations
  - Be changed every 45 days

XII. SEPARATION OF DUTIES

In accordance with the NIST definition of separation of duties, no user shall be given enough privileges to misuse the system on their own, ETS uses dynamic control of security liaison duties. The ETS security liaison reviews and oversees activities of a RACF security technician who runs automated RACF related tasks and takes specific RACF actions as requested by agency liaisons and monitored by the ETS liaison.

XIII. REVIEWS

- Reviews of this Document
  - This document and associated procedures are to be reviewed each calendar year by the ETS security liaison. A log will be kept by the ETS security liaison with the date of review and initials of the reviewer.
  - Changes to this document will be approved by the CIO.
- Reviews of Mainframe Accounts for Compliance
  - Automated monthly reports of each agency's users are sent to their respective security liaisons to empower them to review their user accounts so that management requirements are enforced. If the agency works with FTI (Federal Tax Information) or SSA (Social Security Administration) data then reviews are tracked by their respective security liaisons.
  - Additional account reviews may be conducted by the ETS security liaison.
- Reviews for Detection of Unauthorized Access
  - A daily RACF violation report is sent to the ETS liaison for review. This document identifies attempts by mainframe accounts to access areas that are outside of their defined groups.

- The ETS liaison will coordinate with the respective agency's liaisons to investigate whether there were unauthorized access attempts. Any identified unauthorized activity will be reported to the respective involved agencies' management for further action.

XIV. SYSTEM SOFTWARE

- System software, including but not limited to the operating system, database, and supporting ISV software will be reviewed on a regular basis and updated to supported versions. Security and stability updates to the operating system software will be checked monthly. It and other system software service dates will be tracked to plan for updates before the current software version reaches its end of service life.
- Software updates will be tested and accepted by agencies before integration into the production environment.

XV. VPN SPECIFICATIONS

- Connections to the mainframe traverse an IKEv2 tunnel utilizing AES-256 bit encryption algorithm.
- Data integrity is provided by SHA256 encryption.
- A State firewall and remote hosting network firewall facilitate the VPN tunnel utilized by mainframe users.
- Data traversing the physical infrastructure between the State and remote hosting network are fully encrypted inside of the tunnel.

XVI. SECURITY AWARENESS AND TRAINING

- Security awareness training is based on security requirements of agencies' systems and may vary based on agency and system.
- In accordance with IRS requirements, the following training is required to be completed annually by contractor personnel accessing the mainframe. This is based on The Department of Family Services training:
  - IRS Data Security Video
  - DSA-002 – Statement of Confidentiality Form
  - DSA-003 – Conflict of Interest Disclosure Form
  - DSA-004 – IRC Unauthorized Access and Disclosure of FTI Form
  - DSA-005 – Electronic Transmission of FTI Policy Form

- The completed forms will be used by the agency's security liaison to determine whether the contractor's account will be extended.

XVII. PHYSICAL SECURITY

- Physical security of the mainframe hardware is facilitated by the affiliate FNTS, in their remote datacenter.
- The remote datacenter complies with the SOC2 and PCI DSS standards and requirements.

XVIII. DISASTER RECOVERY EXERCISE

- ETS will perform a mainframe disaster recovery exercise annually.
- Personnel involved will include:
  - Mainframe supervisor
  - Systems programmer to restore the system from backups
  - Database administrator to restore agency databases
  - Mainframe scheduler to verify and start agencies' scheduler tasks
  - POCs from agencies using the mainframe to test their respective systems
  - Other personnel as needed, i.e. networking, firewall, etc.
- RACF security information from backups will restore the mainframe security settings
- An after-action report will be performed at the end of each exercise to identify, capture, and integrate lessons learned from the exercise

REFERENCES: This policy has no supporting references to websites, other policies, federal or state statutes.

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
July 2024	ETS Governance, Risk and Compliance	Public Comment Period	07/26/2024 - 08/09/2024	August 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**